Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 2.2 / COMPANION WORKBOOK

Body of Evidence

Implement and Assess: document, prove, and test the network

Develop the Body of Evidence for the same Inside the Network build through the Risk Management Framework (RMF) Implement and Assess steps, following NIST SP 800-37 Revision 2 with the 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Record the controls as implemented, prove them with indexed evidence, prepare and perform an independent assessment, and carry its findings into a Security Assessment Report (SAR) and a Plan of Action and Milestones (POA&M).

MATERIALS EDITION 2.0 / COURSE 2.2

Updated 15 October 2026 · sbd-rmf-body-of-evidence

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each module alongside the interactive course. Use the record tables to write down what you actually produce — the workbook is your record, not the course.

Before you start

RMF steps, tasks, and outputs

05 Implement and document the controls

06 Connect implementation to proof

07 Prepare the assessment

08 Perform and report the assessment

09 Build the plan of action and milestones

Evidence starters

Knowledge check answers

Sources

Course review and sign-off

> **HOW TO USE IT** Each module page has the same shape: its RMF step with the NIST SP 800-37 Rev. 2 and JSIG tasks and outputs, three short lessons, a worked example, the practice output, and a record table. Fill the tables from your own records — never from the sample values.

Before you start

Develop the Body of Evidence for the same Inside the Network build through the Risk Management Framework (RMF) Implement and Assess steps, following NIST SP 800-37 Revision 2 with the 2016 Joint Special Access Program Implementation Guide (JSIG) mapped in. Record the controls as implemented, prove them with indexed evidence, prepare and perform an independent assessment, and carry its findings into a Security Assessment Report (SAR) and a Plan of Action and Milestones (POA&M).

Prerequisites

- ☐ Course 2.1’s outputs: the scope and registration records, the draft System Security Plan with its categorization, the Security Controls Traceability Matrix, the draft Risk Assessment Report, and the continuous monitoring strategy.
- ☐ Your Inside the Network build, or the supplied sample records.
- ☐ The control and assessment procedure releases your authority has adopted (NIST SP 800-53 and SP 800-53A).

What this course covers

- Implement the controls, document them as built, and prove them with indexed evidence.
- Prepare and perform an independent assessment, and report supported findings in a Security Assessment Report.
- Remediate and reassess what can be fixed now, and carry open findings into a risk-ranked POA&M.

Practice artifacts in this course

- System Security Plan — Describe the system and its categorization, record the plan’s approval, and explain how each selected control is implemented.
- Security Controls Traceability Matrix — Record each selected control’s source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.
- Master evidence index — Make every supporting record retrievable, attributable, current, and traceable to the objectives it supports.
- Security Assessment Plan — Define who assesses, what they receive, and what will be assessed and how, so the results are defensible.
- Security Assessment Report — Record what was assessed, what was observed, the findings and limitations, and the result of any reassessment.
- Risk Assessment Report — Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.
- Plan of Action and Milestones — Turn an open finding into a risk-ranked, resourced, dated plan that the AO can review and use to monitor progress.

© 2026 Secure By Design Team LLC.

RMF steps, tasks, and outputs

Each module follows one Risk Management Framework (RMF) step in NIST SP 800-37 Revision 2 order, with the matching tasks and outputs of the Joint Special Access Program Implementation Guide (JSIG), 11 April 2016.

MODULE	RMF STEP	NIST	JSIG
05 Implement and document the controls	Implement	I-1–I-2	3-1–3-2
06 Connect implementation to proof	Implement	I-1–I-2	3-1–3-2
07 Prepare the assessment	Assess	A-1–A-2	4-1
08 Perform and report the assessment	Assess	A-3–A-5	4-2–4-4
09 Build the plan of action and milestones	Assess	A-6	5-1

TWO DOCUMENTS, ONE SEQUENCE NIST SP 800-37 Revision 2 has seven steps, starting with Prepare. The 2016 JSIG follows Revision 1's six steps, from Categorize to Monitor, with SP 800-53 Revision 4 and CNSSI 1253 (March 2014). Confirm whether your program directs the JSIG, its successor, or other guidance.

© 2026 Secure By Design Team LLC.

Implement and document the controls

> **WHY THIS MATTERS** Implement the selected controls and record them as built in the System Security Plan (SSP) and Security Controls Traceability Matrix (SCTM), in statements an assessor can test.

The RMF step

Who does the work NIST gives I-1 and I-2 to the system owner and any common control provider, with engineers and security staff supporting. The Joint Special Access Program (SAP) Implementation Guide (JSIG) gives Tasks 3-1 and 3-2 to the Information System Owner (ISO), working with the Information System Security Engineer (ISSE).

- NIST I-1 · Control implementation
- NIST I-2 · Update control implementation information
- JSIG Task 3-1 · Implement the security controls specified in the SSP
- JSIG Task 3-2 · Document the control implementation in the SCTM portion of the SSP

What this module produces

- The controls the Build the Network courses put in place, checked against the approved selection and parameter values (NIST I-1; JSIG 3-1)
- As-implemented SSP statements for each practice control: who, what, where, when, and which records (I-2)
- SCTM rows updated with implementation status and evidence references (JSIG 3-2, output “Updated SSP/SCTM”)
- Planned work and differences from the approved plan recorded, not presented as operating
- Supporting plans referenced by owner, version, and review status

JSIG step outputs Updated SSP/SCTM

> **WHERE THE JSIG AND NIST DIFFER** The JSIG records the implementation in the SCTM portion of the SSP. NIST updates the security and privacy plans themselves, with as-implemented detail sufficient for an assessor to use.

Learn

05.1 Implement the approved controls Build what the approved plan describes.

Implement turns the approved plan into a working system. NIST Task I-1 implements the controls in the security and privacy plans; Task 3-1 of the Joint Special Access Program (SAP) Implementation Guide (JSIG) implements those specified in the System Security Plan (SSP).

The system owner is accountable, and engineers build to the approved selection, parameter values, and control revision. That revision matters: the public JSIG is the 11 April 2016 edition, built on SP 800-53 Revision 4 and CNSSI 1253, and a program may direct a successor or its own guidance.

05.2 As-implemented statements Record the controls as they were built.

© 2026 Secure By Design Team LLC.

NIST Task I-2 updates the plans with the as-implemented state, in enough detail for an assessor to use. JSIG Task 3-2 records it in the Security Controls Traceability Matrix (SCTM) portion of the SSP. Both lead to the JSIG output “Updated SSP/SCTM.”

Write who performs each activity, what happens, where it applies, when it happens, and which records show it. “We comply with policy” leaves an assessor nothing to examine, interview, or test.

05.3 Planned work and supporting plans Keep planned work and supporting plans honest.

Describe what operates today, and mark planned work as planned. Where the build could not follow the plan, say so; the assessor will test each statement as written.

Configuration, access, incident response, contingency, and other supporting plans describe processes the SSP relies on. Reference each by owner, version, and review status instead of copying procedures that drift apart. A plan shows intent; records show the process happens.

Worked example: Turn a vague statement into an as-implemented one

1. **Before —** “Audit records are reviewed according to policy.” It names no reviewer, sources, schedule, or record.
2. **As built —** Windows systems forward the selected events to SBD-SYSLOG01 by Windows Event Forwarding (F17), the Linux servers send syslog over TLS (F07), and the collector feeds SBD-SPLUNK01 (F10) and SBD-AUDIT01 (F11).
3. **After —** The assigned analyst reviews those events in SBD-SPLUNK01 on the approved schedule, records each exception and its follow-up, and keeps the review record.
4. **Trace —** Put the statement in the SSP and update the AU-6 row of the SCTM with its status and evidence identifiers, ready for the assessor.

Build

Update the SSP that course 2.1 drafted with as-implemented statements for the practice controls (AU-2, AU-3, AU-6, AU-12): who performs each activity, what happens, where, when, and which records show it. Update the matching SCTM rows with implementation status and evidence references, and mark planned work as planned.

Practice artifacts System Security Plan; Security Controls Traceability Matrix (see Evidence starters)

Think it through

Replace a vague “compliant with policy” statement with a specific as-implemented narrative. Reconcile it with the diagrams, inventory, and inheritance record, and show how you would record a difference between the build and the approved plan.

Check your understanding

The engineers built the log path differently from the approved plan. What does the Implement step call for?

- A. Leave the plan as approved and let the assessor find the difference.

- B. Update the SSP and SCTM to the as-implemented state.
- C. Change the system back, whatever the reason for the difference.

Your record

RECORD	YOUR OBSERVATION
System Security Plan — location and version	
Security Controls Traceability Matrix — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The system security plan describes this network as it is: each VLAN and its systems, the administration tiers, and the permitted paths between them. Every implementation statement names who does what, where, and when.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[6] DoDM 5205.07

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Connect implementation to proof

> **WHY THIS MATTERS** Collect technical and operational evidence of the as-built system, index it, and correct the SSP and SCTM wherever the evidence and the plan disagree.

The RMF step

Who does the work Engineers and administrators produce the records, and common control providers supply evidence for what the system inherits. The system owner (in the JSIG, the ISO with the ISSE) keeps the SSP and SCTM true to that evidence.

- NIST I-1 · Control implementation
- NIST I-2 · Update control implementation information
- JSIG Task 3-1 · Implement the security controls specified in the SSP
- JSIG Task 3-2 · Document the control implementation in the SCTM portion of the SSP

What this module produces

- Configuration evidence with system, scope, version, and collection time: scan results, hardening checklists, exports (I-1)
- Operational records that show processes run, such as log reviews and a restore test
- A master evidence index giving each record an identifier, owner, date, scope, and version
- Coverage gaps and limitations recorded, including credentialed vulnerability scanning not yet available
- SSP and SCTM corrected to the as-built state (I-2; JSIG output “Updated SSP/SCTM”)

JSIG step outputs Updated SSP/SCTM

> **WHERE THE JSIG AND NIST DIFFER** The JSIG calls the record an assessment rests on the Body of Evidence (BoE): the SSP, test plans, test procedures, test reports, and exceptions. NIST SP 800-37 treats the same material task by task: updated plans (I-2), assessment plans (A-2), assessment evidence (A-3), and assessment reports (A-4).

Learn

06.1 Configuration and hardening evidence Capture the configuration and its context.

Evidence shows what Implement actually produced. A configuration export or Security Technical Implementation Guide (STIG) checklist is useful when a reviewer can identify the system, setting, scope, version, and collection time. Keep the review record alongside it.

A passing automated check has a defined scope. Manual checks, applicability decisions, and technical limits still need attention.

06.2 Security operations evidence Show that processes run, and how far the evidence reaches.

Logs, review records, tickets, access reviews, and restore tests support different claims. Connect each item to the question it can answer. Owning a security product does not show that a control is effective; its records might.

© 2026 Secure By Design Team LLC.

Check that every relevant system was included, the collection worked, and the data is current. Keep collection failures rather than silently excluding them, and say what an item cannot show: a backup job's success message does not prove recovery.

06.3 The evidence index and the as-built plan Index the evidence, then let it correct the plan.

A master evidence index gives each record a stable identifier, title, scope, owner, collection date, version, and location, so nobody depends on a folder name or someone's memory. One record can support several objectives, and one objective can need several records.

When the evidence shows the system differs from the SSP or SCTM, update them to the as-built state. That is still NIST Task I-2 and JSIG Task 3-2, and it means the assessor tests the real system.

Worked example: A clean view with a coverage gap

1. **Result —** A Splunk search by host shows recent events from the domain controllers and member servers.
2. **Inspection —** The audit source inventory lists SBD-MGMT01, but none of its events reached SBD-SYSLOG01 in the collection period.
3. **Conclusion —** The evidence does not support complete source coverage, so the SSP's AU-12 statement cannot claim it.
4. **Follow-up —** Record the gap in the evidence index and the SSP, and hand it to the assessor. Do not drop SBD-MGMT01 from the inventory to make the view look complete.

Build

Collect configuration exports, reviewed STIG checklists, SCAP Compliance Checker results with their coverage, log review records, and the course 1.19 restore record, or equivalent supplied training records. Start the master evidence index, and correct the SSP and SCTM wherever the evidence shows the system differs from the plan.

Practice artifacts Master evidence index (see Evidence starters)

Think it through

Explain what each item proves and leaves untested. Identify a scan that missed an in-scope host, an unreviewed alert, and a configuration screenshot that lacks system or time context. Record credentialed vulnerability scanning (RA-5) as a limitation: the practice network does not run it yet.

Check your understanding

A configuration scan reports no open findings, but one in-scope server is missing from its results. What does the scan support?

- A. A clean result for every in-scope server.
- B. Nothing, so it should be deleted.
- C. A clean result for the servers it covered; the missing server is a coverage gap to record and close.

Your record

RECORD	YOUR OBSERVATION
Master evidence index — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Proof comes from the systems themselves: SCAP Compliance Checker results and STIG checklists from the administration seats, log review records from SBD-SPLUNK01, and the course 1.19 restore record.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Prepare the assessment

> **WHY THIS MATTERS** Select an independent assessor, hand over current evidence, and get a Security Assessment Plan approved before any testing starts.

The RMF step

Who does the work The Authorizing Official (AO) or a designated representative selects the assessor (A-1) and, in NIST, approves the plan the assessor develops (A-2). In the JSIG, the ISO develops the plan with the Information System Security Manager (ISSM), Information System Security Officer (ISSO), or ISSE, and the Security Control Assessor (SCA) reviews and approves it (4-1).

- NIST A-1 · Assessor selection
- NIST A-2 · Assessment plan
- JSIG Task 4-1 · Develop, review, and approve a plan to assess the security controls

What this module produces

- An assessor or team selected by the AO or designated representative, with the independence required (NIST A-1)
- A record of the evidence handed over: SSP, SCTM, evidence index, and known exceptions, with versions
- A Security Assessment Plan with scope, objectives, methods, objects, procedures, sampling, schedule, and limits (A-2; JSIG 4-1)
- The plan’s review and approval, recorded before testing (JSIG output “Security Assessment Plan”)

JSIG step outputs Security Assessment Plan

> **WHERE THE JSIG AND NIST DIFFER** Assessor selection is a separate task only in NIST (A-1). NIST has the assessor develop the plan for the AO’s approval; the JSIG has the ISO’s team develop it and the SCA approve it, and defines it as the SSP, the SCTM, and the Security Control Assessment Procedures.

Learn

07.1 Assessor selection and independence Choose an assessor who can be trusted with the answer.

NIST Task A-1 opens Assess: the Authorizing Official (AO), or a designated representative, selects the assessor or team. In the JSIG, Step 4 starts with the plan, and the Security Control Assessor (SCA) is a defined role.

Choose for skill and independence. An impartial assessor does not assess their own work or advocate for the team that built it. The AO decides how much independence the system’s categorization and risk call for.

07.2 The evidence the assessor receives Hand over evidence the assessor can rely on.

The assessor starts from what Implement produced: the SSP, the SCTM, the evidence index, and the exceptions you already know about. Check that each record is current, and record the versions you hand over so the plan and results refer to the same material.

© 2026 Secure By Design Team LLC.

The JSIG describes this as the Body of Evidence (BoE): the SSP, test plans, test procedures, test reports, and exceptions. The system team supplies the plan and the exceptions; the assessment adds the rest.

07.3 The Security Assessment Plan Agree on the plan before anyone tests.

In NIST Task A-2, the assessor develops the plan from the implementation detail, and the AO or a designated representative approves it. In JSIG Task 4-1, the ISO develops it with the information system security manager, officer, or engineer, and the SCA reviews and approves it.

The JSIG's Security Assessment Plan is made up of the SSP, the SCTM, and the Security Control Assessment Procedures. Either way, the plan states scope, objectives, methods, objects, coverage, responsibilities, schedule, and limits, with sampling decisions written down.

Worked example: Plan the logging assessment

1. **Assessor —** The exercise AO's designated representative selects a training assessor who did not build or operate the logging pipeline.
2. **Evidence —** The assessor receives the SSP and SCTM at their recorded versions, evidence index EI-001, and the known SBD-MGMT01 coverage gap.
3. **Procedures —** Examine the event configuration and source records, interview the analyst, test an approved account change on SBD-DC01, and replay the attack drill's six attempts as negative tests.
4. **Approval —** Plan AP-001 is reviewed and approved before any testing: by the SCA in JSIG terms, or by the AO or a designated representative in NIST's.

Build

Record who selected the assessor and the independence they provide. List the evidence handed over, with versions and known exceptions. Draft a Security Assessment Plan for the practice logging objectives: scope, objectives, methods, objects, sampling rationale, the attack drill's six attempts as negative tests, responsibilities, schedule, and limits. Record its review and approval.

Practice artifacts Security Assessment Plan; Master evidence index (see Evidence starters)

Think it through

Check the handover before approval: find stale evidence, a missing record, and a mismatch between the SSP and an exported configuration, and record each gap's effect on the plan. Explain why your assessor is independent enough for this system.

Check your understanding

The engineer who built the logging pipeline offers to assess it. What is the problem?

- A. An assessor should not assess their own work; the AO sets the independence required.
- B. None, as long as the engineer follows the procedures.
- C. Engineers cannot take part in an assessment at all.

Your record

RECORD	YOUR OBSERVATION
Security Assessment Plan — location and version	
Master evidence index — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** The assessor works from records you already keep: the evidence folders on the administration seats, the protected archive on SBD-AUDIT01, and the living inventory on SBD-MGMT01. The assessment plan names which records and systems each procedure covers.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Perform and report the assessment

> **WHY THIS MATTERS** Assess the controls as planned, report supported findings in a Security Assessment Report (SAR), and remediate and reassess what can be fixed now.

The RMF step

Who does the work The control assessor performs the assessment and writes the report; in the JSIG that is the SCA or an AO designee, and the SCA submits the SAR with a recommended authorization decision. The system owner carries out initial remediation, and the assessor reassesses (A-5).

- NIST A-3 · Control assessments
- NIST A-4 · Assessment reports
- NIST A-5 · Remediation actions
- JSIG Task 4-2 · Assess the security controls per the Security Assessment Plan
- JSIG Task 4-3 · Prepare the Security Assessment Report (SAR)
- JSIG Task 4-4 · Conduct initial remediation based on the SAR and reassess remediated controls

What this module produces

- Completed assessments with the observation and evidence for each objective (A-3; JSIG 4-2)
- A SAR with results, findings, limitations, and recommendations (A-4; JSIG output “SAR”)
- Initial remediation and reassessment, with original findings kept in the updated SAR (A-5; JSIG 4-4)
- The SSP updated where an implementation changed (A-5; JSIG output “Updated SSP”)
- The Risk Assessment Report (RAR) updated with the risk from confirmed weaknesses (JSIG output “Updated RAR”)

JSIG step outputs SAR; Updated RAR; Updated SSP

> **WHERE THE JSIG AND NIST DIFFER** The JSIG updates the RAR here and has the SCA submit the SAR with a recommended authorization decision. NIST assesses system risk in Prepare (P-14) and analyzes and determines it in Authorize (R-2); its assessment report carries findings and recommendations for correcting deficiencies.

Learn

08.1 Examine, interview, and test Run the approved procedures and record what you see.

NIST Task A-3 and JSIG Task 4-2 assess the controls the way the approved plan describes. Each assessment asks whether a control is implemented correctly, operating as intended, and producing the desired outcome.

Examine records and configurations, interview the people who run the process, and test behavior where the plan calls for it, including what should fail. Record the expected result, the observation, the evidence, and any limitation, using the adopted SP 800-53A procedures.

08.2 The Security Assessment Report Report only what the evidence supports.

© 2026 Secure By Design Team LLC.

NIST Task A-4 and JSIG Task 4-3 produce the Security Assessment Report (SAR): what was assessed, the result for each objective, the findings and limitations, and recommendations for correcting deficiencies. An objective the evidence cannot support is “other than satisfied,” not a pass by default.

In the JSIG, the SCA submits the SAR with a recommended authorization decision. The recommendation informs the AO; it is not the decision.

08.3 Initial remediation and reassessment Fix what you can, reassess it, and keep the record.

NIST Task A-5 and JSIG Task 4-4 cover initial remediation. Review each finding’s significance; the system owner corrects those that should be fixed now, and the assessor reassesses the changed controls. The SAR keeps the original finding beside the new result.

Then update what the results changed: the SSP for any implementation that moved and, in the JSIG, the Risk Assessment Report (RAR) drafted in Select. Whatever stays open goes to the Plan of Action and Milestones (POA&M).

Worked example: Assess the logging objectives

1. **Test —** Make an approved account change on SBD-DC01 and follow it through SBD-SYSLOG01 to SBD-SPLUNK01 and the analyst’s review. Replay the attack drill: all six attempts should be refused.
2. **Observe —** The event arrives and is reviewed (EV-003, EV-004), and every drill attempt is refused. SBD-MGMT01 has no verified events in the period, and one review exception has no recorded follow-up.
3. **Report —** SAR-001 records the results, FND-001 for SBD-MGMT01 coverage, and FND-002 for the missing follow-up, and cites the traffic matrix for the drill.
4. **Remediate —** The analyst records the follow-up, and the reassessment finds the AU-6 objective satisfied; FND-002 stays in the report as remediated. FND-001 needs a scheduled change, so it stays open for the POA&M.

Build

Run the procedures in your approved plan and prepare a SAR excerpt. Include negative tests: run the six attempts in the Inside the Network attack drill, record each expected and observed result in the Operational verification column of the network traffic matrix, and cite the matrix in your SAR. Remediate one finding, reassess it, and update the SSP and the Risk Assessment Report (RAR) that course 2.1 drafted.

Practice artifacts Security Assessment Report; Risk Assessment Report (see Evidence starters)

Think it through

Link each conclusion to its objective, evidence, observation, and limitation. Record unsupported objectives as other than satisfied rather than treating missing evidence as a pass, and show a remediated finding still in the report beside its reassessment.

Check your understanding

During the assessment, the team fixes a finding and the reassessment passes. What happens to the original finding in the SAR?

- A. It is deleted, since the control now works.
- B. It stays, with the remediation and the reassessment result beside it.
- C. It moves to the POA&M as an open item.

Your record

RECORD	YOUR OBSERVATION
Security Assessment Report — location and version	
Risk Assessment Report — location and version	
Reviews or approvals recorded	
Open questions carried forward	

> **IN YOUR NETWORK** Assessment tests what should fail as well as what should work. The attack drill's six attempts should all be refused; the three that cross VLANs are drawn here: a PC to SQL, a PC to Splunk, and a stolen session on SBD-ADMIN-PC01 aimed at a domain controller.

[1] NIST SP 800-37 Revision 2

[3] NIST SP 800-53A Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Build the plan of action and milestones

WHY THIS MATTERS Turn the findings still open into a risk-ranked Plan of Action and Milestones (POA&M) with accountable owners, resources, dated milestones, and closure criteria.

The RMF step

Who does the work NIST gives A-6 to the system owner and any common control provider. In the JSIG, the ISO initiates and updates the POA&M (5-1), and the AO uses it to monitor progress.

- NIST A-6 · Plan of action and milestones
- JSIG Task 5-1 · Initiate and update the POA&M from the SAR's findings and recommendations

What this module produces

- A POA&M entry for each finding still open after initial remediation (A-6; JSIG output "POA&M")
- Entries ranked by contextual risk, not technical severity alone
- An accountable owner, resources, milestones, and completion dates for each entry
- Closure criteria tied to reassessment, linked to the SAR finding and the RAR

JSIG step outputs POA&M

WHERE THE JSIG AND NIST DIFFER NIST prepares the POA&M at the end of Assess (A-6); the JSIG initiates it as the first task of Authorize (5-1). Both build it from the assessment report's findings and recommendations.

Learn

09.1 From findings to ranked risk Rank what is still open by risk.

Findings that survive initial remediation go into the Plan of Action and Milestones (POA&M). NIST Task A-6 prepares it from the assessment report's findings and recommendations; JSIG Task 5-1 initiates it the same way, as the first task of Authorize.

Rank the entries by risk in the system's context: threat, exposure, mission consequence, existing safeguards, and remaining uncertainty. Technical severity informs the order, but it is not the complete risk determination.

09.2 Writing an actionable POA&M Write an action someone can manage.

Each entry names the weakness, affected scope, accountable owner, planned actions, resources, milestones with completion dates, dependencies, and closure criteria. In the JSIG, the ISO keeps it updated with corrective actions, resources, milestone completion dates, and residual findings.

"Fix soon" is not a milestone. A useful milestone describes a verifiable action with a target date and a clearly accountable owner.

09.3 Tracking to verified closure Track each entry to verified closure.

The AO reviews the POA&M and uses it to monitor progress. Close an entry only when a reassessment verifies the fix, and keep the original finding and dates when plans change.

© 2026 Secure By Design Team LLC.

A POA&M is a management record; it does not accept risk or grant permission to operate. Tracking a weakness and accepting its risk are different actions, and only the AO accepts risk.

Worked example: Turn the open logging finding into a POA&M entry

1. **Finding —** FND-001: SBD-MGMT01 is not in verified audit collection. It remained open after initial remediation because the fix needs a scheduled change.
2. **Risk —** Privileged activity on a management server could go unreviewed. Weigh the local records that remain, then set the entry's contextual risk and rank.
3. **Milestones —** Confirm the forwarding configuration, test a selected event end to end, and verify the analyst's review covers SBD-MGMT01, each with an owner and a date.
4. **Closure —** Close PM-001 only after reassessment, then update the SSP, evidence index, RAR, and SAR. FND-002 was fixed during the assessment and needs no entry.

Build

Rank the findings still open after initial remediation and write a POA&M entry for each: the weakness, affected assets and controls, owner, resources, milestones with target dates, status, and closure criteria tied to reassessment. Link each entry to its SAR finding and the RAR.

Practice artifacts Plan of Action and Milestones (see Evidence starters)

Think it through

Prioritize two findings with different exposure and mission impact, and defend the order. Explain why a finding fixed and reassessed during the assessment needs no entry, and why an open entry cannot close without a verified reassessment.

Check your understanding

Does adding a finding to the POA&M mean its risk has been accepted?

- A. Yes, automatically.
- B. Only if the entry has a due date.
- C. No. Only the AO accepts risk, as part of the authorization decision.

Your record

RECORD	YOUR OBSERVATION
Plan of Action and Milestones — location and version	
Reviews or approvals recorded	

RECORD	YOUR OBSERVATION
Open questions carried forward	

> **IN YOUR NETWORK** The worked finding is in this network: SBD-MGMT01 missing from verified audit collection. The POA&M entry restores collection, retests the selected event, and keeps the original result until the retest verifies the fix.

[1] NIST SP 800-37 Revision 2

[2] NIST SP 800-53 Revision 5

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

Evidence starters

Blank starters for the practice artifacts this course produces. Fill them from your own system. The interactive course shows a completed fictional example of each, and the training materials download includes each one as Markdown (and CSV for tables).

System Security Plan

System description to as-built controls Owner: System owner with the security team and engineers. Describe the system and its categorization, record the plan's approval, and explain how each selected control is implemented.

FIELD	YOUR ENTRY
System description — Name, identifier, mission, boundary, components, environment, and references (NIST C-1; JSIG 1-2).	
Security categorization — Information types; confidentiality, integrity, and availability impacts with rationale; method; reviewer; approval (C-2, C-3; JSIG 1-1).	
Plan review and approval — Version reviewed, reviewer and role, date, decision, and any conditions (S-6; JSIG 2-4).	
As-implemented control statements — Control ID and adopted revision, approved parameters (from the SCTM), and who does what, where, when, and with which records (I-2; JSIG 3-2).	
Evidence and responsibilities — Evidence identifiers, owners, provider dependencies, and review status.	
Limitations and planned work — Separate what operates from planned work and known gaps.	

© 2026 Secure By Design Team LLC.

FIELD	YOUR ENTRY
Recorded risk decisions — Risk responses, rationale, mitigation, decision owner, and review trigger.	

The example is an excerpt, not a full SSP or a finding of compliance. In the JSIG, the SSP also includes the SCTM, the continuous monitoring strategy, and a Risk Assessment Report; this course keeps them as separate practice artifacts.

Security Controls Traceability Matrix

Requirement to implementation Owner: System owner (ISO) and security team, with implementation owners. Record each selected control's source, tailoring, parameters, allocation, and inheritance, then trace it to implementation, evidence, and results. Started in Select; module 05 adds the as-implemented statements.

CONTROL	SELECTION AND TAILORING	PARAMETERS	ALLOCATION AND INHERITANCE	IMPLEMENTATION AND TRACE
[ID / title / adopted revision]	[Baseline or overlay source; tailoring decision, rationale, approval]	[Organization-defined values and their source]	[System-specific, common, or hybrid; provider and what it supplies; components; owner]	[Planned (module 04), then as implemented (module 05); evidence, result, and finding IDs]

Mappings are instructional. Expand rows to the exact selected control parts and assessment objectives; a single record doesn't prove an entire control. In the JSIG, the SCTM is part of the System Security Plan.

Master evidence index

Evidence inventory Owner: Evidence custodian and control owners. Make every supporting record retrievable, attributable, current, and traceable to the objectives it supports.

ID	RECORD	SCOPE / OWNER	COLLECTION / VERSION	SUPPORTS
[EV-ID]	[Title and approved location]	[System scope / owner]	[Date / version / reviewer]	[Control, objective, and limits]

This index describes sample records. The referenced technical exports are exercise specifications, not attached operational evidence. Keep superseded versions: the assessment refers to the versions it received.

Security Assessment Plan

Assessment design Owner: Control assessor and system owner. Define who assesses, what they receive, and what will be assessed and how, so the results are defensible.

FIELD	YOUR ENTRY
Assessor and independence — Assessor or team, who selected them, and the independence they provide (NIST A-1).	
Evidence received — Documents and records handed over, with versions, dates, and known exceptions.	
Scope and objectives — System and version, selected controls and objectives, exclusions, assumptions.	
Methods, objects, and expected results — Examine, interview, or test for each objective; objects; coverage and sampling rationale; expected results.	
Responsibilities, schedule, and approval — Assessor, system contacts, dates, and the plan's review and approval (A-2; JSIG 4-1; CA-2).	
Limitations and safety — Collection limits, access needs, constraints, authorized test conditions.	

Assessment plan is written in full here to avoid confusing its acronym with Special Access Program. In the JSIG, the Security Assessment Plan is made up of the SSP, the SCTM, and the Security Control Assessment Procedures; this excerpt shows the procedures.

Security Assessment Report

Observed assessment results Owner: Control assessor (the JSIG's security control assessor). Record what was assessed, what was observed, the findings and limitations, and the result of any reassessment.

FIELD	YOUR ENTRY
Assessment basis — Approved plan, scope and version, objectives, dates, assessor.	

FIELD	YOUR ENTRY
Observed results — Actual observation and evidence for each objective; satisfied or other than satisfied.	
Findings — Finding ID, affected scope, requirement and objective, evidence, effect.	
Conclusions and limitations — Supported determinations, missing support, scope limits.	
Recommendations — Corrections the assessor recommends and, in the JSIG, the SCA's recommended authorization decision.	
Initial remediation and reassessment — What was corrected, the reassessment result, and the original finding kept (A-5; JSIG 4-4).	

The report is a fictional excerpt for practicing traceability and assessment writing. A reassessment adds results to the report; it never removes the original finding.

Risk Assessment Report

Risk analysis Owner: System owner (ISO) with the ISSM and ISSO. Record the risks that remain with the selected controls, how likely and harmful each is, and what the assessment must confirm. Drafted in Select as a JSIG Step 2 output; module 08 updates it with assessment results.

RISK	PLANNED SAFEGUARDS	LIKELIHOOD AND IMPACT	RISK LEVEL	RESPONSE AND NEXT UPDATE
[RSK-ID: threat event, the weakness or condition it exploits, and what it affects]	[Selected controls from the Security Controls Traceability Matrix (SCTM) that address it]	[Ratings and reasons, using the authority's method and scale]	[Result, confidence, and assumptions]	[Planned response and owner; what the assessment must confirm (module 08)]

Ratings are exercise values, not an assessment of any real system; use the method and scale your authority directs. In the JSIG's authorization package, the System Security Plan includes a RAR (Task 5-2). Only the AO accepts risk.

Plan of Action and Milestones

Accountable corrective action Owner: System owner and remediation owner. Turn an open finding into a risk-ranked, resourced, dated plan that the AO can review and use to monitor progress.

FIELD	YOUR ENTRY
Finding and affected scope — POA&M ID, finding ID, controls and objectives, affected assets.	
Risk and priority — Threat, exposure, mission consequence, current safeguards, uncertainty, and the resulting rank.	
Owner, resources, and milestones — Accountable owner, actions, resources, target dates, dependencies.	
Closure criteria — What must be verified, by whom, and with which record.	
Status and decision — Open or closed, milestone updates, the AO’s review, any risk decision reference.	

Milestone tracking and risk acceptance are separate responsibilities. Follow the authority’s required POA&M format. FND-002 has no entry because it was fixed and reassessed during the assessment.

Knowledge check answers

05 The engineers built the log path differently from the approved plan. What does the Implement step call for?

B. Update the SSP and SCTM to the as-implemented state. NIST Task I-2 and JSIG Task 3-2 record the controls as actually implemented. The assessor tests that record, so it has to match the system.

06 A configuration scan reports no open findings, but one in-scope server is missing from its results. What does the scan support?

C. A clean result for the servers it covered; the missing server is a coverage gap to record and close. A result supports only the scope it covered. Keep it, record the gap, and collect the missing evidence before anyone relies on the result.

07 The engineer who built the logging pipeline offers to assess it. What is the problem?

A. An assessor should not assess their own work; the AO sets the independence required. Independence keeps the result credible. The engineer still takes part, as someone the assessor interviews and observes.

08 During the assessment, the team fixes a finding and the reassessment passes. What happens to the original finding in the SAR?

B. It stays, with the remediation and the reassessment result beside it. Initial remediation (NIST A-5, JSIG 4-4) adds the reassessment to the report; it does not erase what the assessment found. Findings that remain open go to the POA&M.

09 Does adding a finding to the POA&M mean its risk has been accepted?

C. No. Only the AO accepts risk, as part of the authorization decision. The POA&M plans and tracks corrective action. Accepting the remaining risk is a separate decision that belongs to the AO.

© 2026 Secure By Design Team LLC.

Sources

Choose the applicable authority and record the adopted versions before using a template. Module reference numbers correspond to these documents.

[1] NIST SP 800-37 Revision 2

RMF lifecycle, tasks and outputs, authorization package, roles, and monitoring. See Chapter 3 and Appendix E.

[2] NIST SP 800-53 Revision 5

Security and privacy control catalog. Record the release adopted by the governing authority.

[3] NIST SP 800-53A Revision 5

Control assessment procedures and examine, interview, and test methods.

[4] NIST SP 800-53B

Control baselines, tailoring, and overlays. Apply the appropriate system context.

[5] DoDI 8510.01

Risk Management Framework for DoD Systems, July 19, 2022.

[6] DoDM 5205.07

Special Access Program Security Manual, January 17, 2025.

[7] DCSA Voice of Industry · September 2025

DCSA newsletter for cleared industry on the DAAG transition. Confirm the current guide, version, and effective date with DCSA.

[8] JSIG · Joint SAP Implementation Guide, 11 April 2016

The six RMF steps, tasks, and outputs for Special Access Program (SAP) systems, built on NIST SP 800-37 Revision 1, SP 800-53 Revision 4, and CNSSI 1253 (March 2014). Confirm whether your program directs it or a successor.

© 2026 Secure By Design Team LLC.

Course review and sign-off

Before moving on, confirm each module left its outputs behind — and that what remains open is written down.

Module completion

MODULE	OUTPUTS FILED	DATE
05 Implement and document the controls	☐ yes	
06 Connect implementation to proof	☐ yes	
07 Prepare the assessment	☐ yes	
08 Perform and report the assessment	☐ yes	
09 Build the plan of action and milestones	☐ yes	

Open items carried forward

Next in the learning path

That completes Body of Evidence. Course 2.3, Authorization to Operate, assembles the package, supports the authorizing official's decision, and keeps the authorization current.

> **KEEP IT HONEST** Course completion records learning activity. It is not a system authorization, an assessment result, or an approval by any authorizing official. Exercise records are fictional.

© 2026 Secure By Design Team LLC.